

Welcome to

Web Attacks II – Tools, Labs & Defence

Saint Cyber – Cyber Akademiet, 2026

Henrik Kramselund he/him han/ham hlk@zencurity.com @kramse

Slides are available as PDF, https://codeberg.org/kramse
academy-2026-day2-web-attacks-II.tex in the repo security-courses

© license CC BY 3.0. 2026 Henrik Kramselund

Goals for today



- Use relevant assessment tools in an authorised lab: Burp Suite, OWASP ZAP, SQLmap, Wireshark
- Demonstrate web attacks against a controlled vulnerable application
- Evaluate preventive controls and communicate findings

Plan for today



- Tools of the trade
- Lab: OWASP Juice Shop
- Hands-on: SQL injection and XSS
- Defences and preventive controls
- Reporting findings

Time schedule



- **FIXME:** 1) Tools – XX min
- **FIXME:** 2) Juice Shop hands-on – XX min
- **FIXME:** 3) Defences – XX min
- **FIXME:** 4) Reporting + exercise – XX min

Tools of the trade



- **FIXME:** Burp Suite – intercepting proxy
- **FIXME:** OWASP ZAP
- **FIXME:** SQLmap
- **FIXME:** Wireshark

Lab: OWASP Juice Shop



- **FIXME:** run it in Docker on a VM, browse to the app
- Main site: https://juice-shop.github.io/
- Companion guide: https://pwning.owasp-juice.shop/companion-guide/latest/
- Source: https://github.com/juice-shop/juice-shop

Hands-on: SQL injection on Juice Shop



- **FIXME:** the login-bypass / data-extraction walkthrough

Hands-on: XSS on Juice Shop



- **FIXME:** the XSS challenge walkthrough

Defences: input validation & output encoding



- **FIXME:** validate input, encode output in context

Defences: parameterised queries



- **FIXME:** prepared statements / ORM

Defences: secure cookies & anti-CSRF



- **FIXME:** Secure/HttpOnly/SameSite, anti-CSRF tokens

Reporting findings – technical & management



- **FIXME:** document evidence, assess impact, prioritise remediation
- **FIXME:** write for both technical and management audiences

Exercise



- **FIXME:** the hands-on exercise / capstone for the cadets

Summary & references



- **FIXME:** recap tools + attacks + defences
- *Web Application Security*, Andrew Hoffman, 2020, ISBN: 9781492053118 (WAS)
- **FIXME:** add any other references you use